

# TECHSECURE LTD.

## Cybersecurity Foundations Assessment Report

---

Prepared by: Cybersecurity Analyst — TechSecure Ltd. Security Division

Course: Cybersecurity Foundations

Date: March 30, 2026

**CONFIDENTIAL — FOR INTERNAL USE ONLY**

# 1. Executive Summary

This report presents a comprehensive cybersecurity assessment conducted for TechSecure Ltd., a mid-sized organization managing sensitive customer data, intellectual property, and critical infrastructure. Following a recent phishing-based intrusion attempt, this assessment was commissioned by management to evaluate the organization's current security posture and recommend appropriate controls.

The assessment identifies and classifies organizational assets, maps potential threat actors, calculates vulnerability scores using the CVSS v3.1 framework, performs both qualitative and quantitative risk assessments, and recommends security controls aligned with NIST Cybersecurity Framework and CIS Critical Security Controls. Key findings include a critical CVSS score of 9.6 for the phishing vulnerability and an estimated annualized loss expectancy of \$200,000 from credential-based attacks alone.

# 2. Introduction

TechSecure Ltd. is a fictitious mid-sized technology company whose operations depend on the secure management of customer personally identifiable information (PII), proprietary intellectual property, and critical IT infrastructure. As a newly recruited cybersecurity analyst, this report fulfills management's request for a full security assessment following a phishing-based intrusion attempt.

Phishing represents one of the most pervasive and dangerous attack vectors in modern cybersecurity. Despite the presence of technical controls such as firewalls, phishing exploits human vulnerability rather than technical weaknesses — an employee who clicks a malicious link effectively opens the door from the inside, bypassing perimeter defenses entirely. This underscores the critical importance of layered security controls encompassing both technical and administrative measures.

# 3. Asset Identification and Classification

Asset classification is the foundation of any cybersecurity program. By categorizing assets according to their sensitivity level, organizations can prioritize protection efforts and allocate resources effectively. Assets are classified as Public, Internal, or Confidential based on the potential impact of unauthorized disclosure.

| # | Asset                             | Category | Sensitivity  |
|---|-----------------------------------|----------|--------------|
| 1 | Customer PII Database             | Data     | Confidential |
| 2 | Customer Records / CRM System     | Data     | Confidential |
| 3 | Authentication Credentials        | Data     | Confidential |
| 4 | Employee HR Records               | Data     | Confidential |
| 5 | Financial Records / Bank Accounts | Data     | Confidential |
| 6 | Encryption Keys / Certificates    | Data     | Confidential |
| 7 | Access Control Lists (ACLs)       | Process  | Confidential |

|    |                                  |               |          |
|----|----------------------------------|---------------|----------|
| 8  | Internal Policy Documents        | Data          | Internal |
| 9  | Workstations / Laptops / Servers | Hardware      | Internal |
| 10 | Corporate Email System           | Software/Data | Internal |
| 11 | Company Website                  | Software      | Public   |
| 12 | Product / Service Catalog        | Data          | Public   |
| 13 | Industry / Company Profile       | Data          | Public   |
| 14 | Marketing Materials              | Data          | Public   |

*Note: Confidential assets represent the highest priority for protection and require the most robust controls, continuous monitoring, and immediate incident response if compromised.*

## 4. Threat Actor Mapping

Understanding who might attack TechSecure Ltd. and why is essential for designing effective defenses. Each threat actor has distinct motivations, targets, and methods that inform our control selection.

| # | Threat Actor   | Motivation              | Target Asset            | Likely Method                   |
|---|----------------|-------------------------|-------------------------|---------------------------------|
| 1 | Cybercriminal  | Financial gain          | Customer payment data   | Phishing, credential theft      |
| 2 | Nation-State   | Industrial espionage    | Intellectual property   | Spear phishing, malware         |
| 3 | APT            | Long-term disruption    | Critical infrastructure | Persistent backdoor access      |
| 4 | Insider Threat | Accidental or malicious | Any internal asset      | Weak passwords, phishing clicks |

*The Insider Threat is particularly relevant to TechSecure Ltd.'s recent phishing incident. Employees with legitimate access who inadvertently click malicious links represent one of the most common and difficult-to-defend attack vectors, as their activity appears normal to technical controls.*

## 5. CVSS Score Calculation

The Common Vulnerability Scoring System (CVSS) v3.1 provides a standardized method for rating the severity of vulnerabilities. Scores range from 0.0 (None) to 10.0 (Critical). The following vulnerability was scored based on TechSecure Ltd.'s phishing incident scenario:

### Vulnerability: Weak/Compromised Employee Credentials Enabling Unauthorized Remote Access

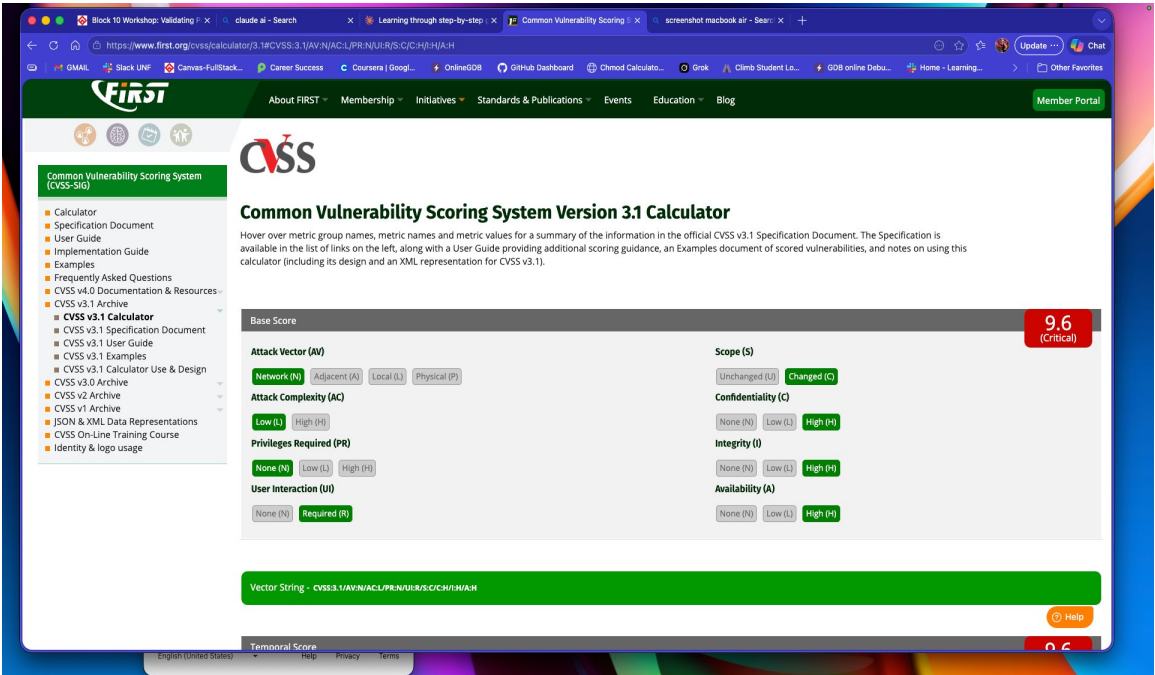
| Metric              | Value       | Rationale                                                      |
|---------------------|-------------|----------------------------------------------------------------|
| Attack Vector       | Network (N) | Attacker exploits remotely over the internet                   |
| Attack Complexity   | Low (L)     | Phishing requires no special conditions or technical expertise |
| Privileges Required | None (N)    | Attacker has no prior system access                            |

|                        |              |                                                                  |
|------------------------|--------------|------------------------------------------------------------------|
| User Interaction       | Required (R) | Employee must click the phishing link                            |
| Scope                  | Changed (C)  | Attacker pivots laterally to other systems beyond initial access |
| Confidentiality Impact | High (H)     | Full access to customer PII and internal data                    |
| Integrity Impact       | High (H)     | Attacker can modify or delete data                               |
| Availability Impact    | High (H)     | Attacker can disrupt or shut down critical systems               |

CVSS v3.1 Base Score: 9.6 — CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Figure 1: CVSS v3.1 Calculator — TechSecure Ltd. Phishing Vulnerability



The score of 9.6 (Critical) reflects the combination of easy execution, remote accessibility, lateral movement potential, and full CIA Triad impact. This places the phishing vulnerability among the most serious risk categories, warranting immediate remediation.

CIA Triad Impact Analysis

The CIA Triad — Confidentiality, Integrity, and Availability — forms the cornerstone of cybersecurity assessment. All three dimensions are critically impacted by this vulnerability:

| Dimension       | Impact | Description                                                                                   |
|-----------------|--------|-----------------------------------------------------------------------------------------------|
| Confidentiality | HIGH   | Attacker gains unauthorized access to customer PII, vendor data, and internal company records |
| Integrity       | HIGH   | Attacker may modify, delete, or corrupt confidential data without authorization               |
| Availability    | HIGH   | Attacker could access root systems and disrupt or shut down critical infrastructure           |

# 6. Risk Matrix — Quantitative Assessment

Quantitative risk assessment assigns monetary values to risks, enabling data-driven decision making and security budget justification. Three core metrics are used:

| Metric                              | Formula                       | Definition                       |
|-------------------------------------|-------------------------------|----------------------------------|
| SLE (Single Loss Expectancy)        | Asset Value x Exposure Factor | Cost of one successful attack    |
| ARO (Annualized Rate of Occurrence) | Historical / Expert Estimate  | Expected attacks per year        |
| ALE (Annualized Loss Expectancy)    | SLE x ARO                     | Expected annual cost of the risk |

| # | Threat                      | Asset                   | Value       | Exposure | SLE       | ARO | ALE       | Risk   |
|---|-----------------------------|-------------------------|-------------|----------|-----------|-----|-----------|--------|
| 1 | Phishing / Credential Theft | Customer Database       | \$500,000   | 80%      | \$400,000 | 0.5 | \$200,000 | HIGH   |
| 2 | Insider Threat              | HR Records              | \$200,000   | 60%      | \$120,000 | 0.3 | \$36,000  | MEDIUM |
| 3 | APT / Malware               | Critical Infrastructure | \$1,000,000 | 90%      | \$900,000 | 0.2 | \$180,000 | HIGH   |

*Key Insight: Although Scenario 3 (APT/Malware) carries the highest single loss exposure (\$900,000), its lower frequency (ARO 0.2) results in a lower annualized cost (\$180,000) than Scenario 1 (\$200,000). This illustrates why ALE is a more actionable metric than SLE alone for budget prioritization.*

# 7. Qualitative vs. Quantitative Risk Assessment

| Dimension     | Quantitative                | Qualitative                   |
|---------------|-----------------------------|-------------------------------|
| Based on      | Numbers and math            | Judgment and experience       |
| Output        | Dollar amounts, CVSS scores | High / Medium / Low ratings   |
| Strength      | Precise, justifies budget   | Fast, flexible, intuitive     |
| Weakness      | Requires accurate data      | Subjective, varies by analyst |
| Example       | ALE = \$200,000             | Phishing Risk = HIGH          |
| Best used for | Executive budget decisions  | Quick risk prioritization     |

## Qualitative Risk Matrix

| Likelihood \ Impact | Low Impact | Medium Impact | High Impact |
|---------------------|------------|---------------|-------------|
| High Likelihood     | MEDIUM     | HIGH          | CRITICAL    |
| Medium Likelihood   | LOW        | MEDIUM        | HIGH        |

|                |     |     |      |
|----------------|-----|-----|------|
| Low Likelihood | LOW | LOW | HIGH |
|----------------|-----|-----|------|

| # | Threat                      | Likelihood | Impact | Qualitative Risk Level |
|---|-----------------------------|------------|--------|------------------------|
| 1 | Phishing / Credential Theft | High       | High   | HIGH                   |
| 2 | Insider Threat              | Medium     | Medium | MEDIUM                 |
| 3 | APT / Malware               | Low        | High   | HIGH                   |

# 8. Security Controls and Control Matrix

Security controls are safeguards implemented to reduce risk to organizational assets. Controls are classified by function (Preventive, Detective, Corrective) and category (Technical, Administrative, Physical). Effective security programs implement defense in depth — layering multiple controls so that if one fails, others compensate.

| Control Type | Definition                        | Example                              |
|--------------|-----------------------------------|--------------------------------------|
| Preventive   | Stops the attack before it occurs | Password policy, MFA, firewall       |
| Detective    | Identifies attacks as they happen | IDS, audit logs, SIEM                |
| Corrective   | Restores systems after an attack  | Data backups, incident response plan |

## Control Matrix — Risk to Control Mapping

| # | Threat                      | Risk Level | Recommended Controls                              | Type                    | Category          |
|---|-----------------------------|------------|---------------------------------------------------|-------------------------|-------------------|
| 1 | Phishing / Credential Theft | HIGH       | Password Policy, MFA, Security Awareness Training | Preventive              | Admin / Technical |
| 2 | Insider Threat              | MEDIUM     | Access Control Lists, Audit Logs, HR Policies     | Detective / Preventive  | Technical / Admin |
| 3 | APT / Malware               | HIGH       | IDS, Antivirus, Network Segmentation              | Detective / Preventive  | Technical         |
| 4 | Data Breach                 | HIGH       | Encryption, Data Backups, Incident Response Plan  | Preventive / Corrective | Technical         |

*Multi-Factor Authentication (MFA) deserves special emphasis: even if an attacker successfully steals credentials through phishing, MFA prevents system access without possession of the second factor — significantly neutralizing the primary attack vector identified in this assessment.*

# 9. GRC Frameworks

Governance, Risk Management, and Compliance (GRC) frameworks provide structured guidance for building and maintaining effective cybersecurity programs. TechSecure Ltd.'s assessment is aligned with two industry-standard frameworks:

## 9.1 NIST Cybersecurity Framework (CSF)

The National Institute of Standards and Technology (NIST) Cybersecurity Framework provides a risk-based approach to managing cybersecurity organized around five core functions:

| NIST Function | Definition                 | Applied in This Assessment              |
|---------------|----------------------------|-----------------------------------------|
| Identify      | Know your assets and risks | Asset classification table, Risk matrix |

|         |                           |                                       |
|---------|---------------------------|---------------------------------------|
| Protect | Implement safeguards      | Control matrix, Password policy, MFA  |
| Detect  | Monitor for threats       | IDS, audit logs, SIEM recommendations |
| Respond | React to incidents        | Incident response plan recommendation |
| Recover | Restore normal operations | Data backup controls                  |

## 9.2 CIS Critical Security Controls

The Center for Internet Security (CIS) provides 18 prioritized security controls. The following are most relevant to TechSecure Ltd.:

| CIS Control                               | Relevance to TechSecure Ltd.                    |
|-------------------------------------------|-------------------------------------------------|
| Control 4 — Secure Configuration          | Password policy configuration on Windows Server |
| Control 5 — Account Management            | User access controls and privilege management   |
| Control 14 — Security Awareness Training  | Anti-phishing training for all employees        |
| Control 17 — Incident Response Management | Structured response to future attacks           |

# 10. NIST-Based Password Policy Configuration

NIST Special Publication 800-63B provides updated guidance on password policy. The following configuration was designed for TechSecure Ltd.'s Windows Server 2022 environment in alignment with NIST and CIS Control 4 recommendations.

## 10.1 Recommended Password Policy Settings

| Policy Setting             | Configured Value | NIST Rationale                                  |
|----------------------------|------------------|-------------------------------------------------|
| Minimum Password Length    | 12 characters    | Length is primary driver of password strength   |
| Password Complexity        | Enabled          | Requires uppercase, lowercase, numbers, symbols |
| Maximum Password Age       | 365 days         | NIST recommends against frequent forced changes |
| Password History           | 10 passwords     | Prevents reuse of recent passwords              |
| Account Lockout Threshold  | 5 attempts       | Mitigates brute force and credential stuffing   |
| Account Lockout Duration   | 30 minutes       | Balances security with operational impact       |
| Lockout Observation Window | 30 minutes       | Resets failed attempt counter after 30 minutes  |

## 10.2 Configuration Steps — Windows Server 2022

1. Open Local Security Policy (secpol.msc) with Administrator privileges
2. Navigate to: Security Settings > Account Policies > Password Policy
3. Configure all password policy settings per the table above
4. Navigate to: Security Settings > Account Policies > Account Lockout Policy
5. Configure lockout threshold (5 attempts), duration (30 min), and observation window (30 min)
6. Install PassFiltEx and configure custom password blocklist (common/weak passwords)
7. Update Windows Registry to enforce PassFiltEx as the active password filter
8. Test policy enforcement by attempting non-compliant password changes
9. Validate from Kali Linux terminal using crackmapexec or hydra to confirm lockout triggers

*Note: Technical configuration steps were designed for Windows Server 2022 running in VirtualBox. Screenshots of completed configuration will be appended upon successful VM access restoration.*

# 11. Kali Linux Validation

Kali Linux serves as the penetration testing platform for validating password policy enforcement. By simulating an attacker's perspective from Kali, we verify that the controls configured on Windows Server 2022 function as intended.

## **Validation Steps from Kali Linux Terminal:**

1. Identify Windows Server IP address on the shared VirtualBox network
2. Attempt SMB connection using a known weak/blocked password — confirm rejection
3. Attempt multiple failed logins to trigger account lockout policy
4. Confirm lockout activates after 5 failed attempts
5. Verify locked account cannot authenticate even with correct password during lockout window
6. Document all terminal output as evidence of policy enforcement

*Note: Kali Linux validation screenshots will be appended upon resolution of VM connectivity. The validation methodology above follows NIST SP 800-115 technical security testing guidelines.*

## 12. Conclusion

This assessment demonstrates that TechSecure Ltd. faces significant and quantifiable cybersecurity risks, with the phishing-based credential theft vulnerability scoring a critical 9.6 on the CVSS v3.1 scale and carrying an estimated annualized loss expectancy of \$200,000.

The organization's primary threat actors — Cybercriminals, Nation-State actors, APTs, and Insider Threats — each target distinct assets for different motivations, reinforcing the need for a layered, defense-in-depth security posture rather than reliance on any single control.

The recommended controls — including MFA, password policy enforcement, security awareness training, network segmentation, and incident response planning — are aligned with the NIST Cybersecurity Framework and CIS Critical Security Controls, providing TechSecure Ltd. with a structured, standards-based foundation for building organizational resilience.

GRC frameworks are not merely compliance exercises — they represent the operational language through which security decisions are made, justified to leadership, and continuously improved. By embedding these frameworks into TechSecure Ltd.'s security culture, the organization moves from reactive incident response toward proactive risk management.

## 13. References

- NIST Special Publication 800-63B — Digital Identity Guidelines (2017)
- NIST Cybersecurity Framework v1.1 — National Institute of Standards and Technology
- CIS Critical Security Controls v8 — Center for Internet Security (2021)
- CVSS v3.1 Specification Document — FIRST.org (2019)
- NIST Special Publication 800-115 — Technical Guide to Information Security Testing (2008)
- CVSS v3.1 Calculator — <https://www.first.org/cvss/calculator/3.1>